

CO5 – AT3 VIVA QUESTIONS

Simple, Easy-to-Speak Detailed Answers

Course Outcome: CO5 – Security analysis of Windows, Linux, messaging, web, and mobile applications.

1. How would you evaluate the security posture of a Windows system after identifying multiple open services?

Answer: First, identify all open services and check whether they are necessary. Check service versions, configurations, known vulnerabilities, firewall rules, permissions, and network exposure. Evaluate the possible impact and classify the risk. Finally, recommend disabling unnecessary services and applying security updates.

2. Which factors would you consider when choosing a hacking tool for Windows vulnerability assessment, and why?

Answer: Consider the purpose of the assessment, accuracy, compatibility with Windows, safety, vulnerability coverage, ease of use, and reporting capability. The tool should match the testing objective and be used only with proper authorization.

3. How would you evaluate the security risk associated with an exposed RPC service?

Answer: RPC (Remote Procedure Call) allows applications and services to communicate remotely. Check whether the service is required, whether it is accessible from untrusted networks, its version, patches, authentication, firewall restrictions, and known vulnerabilities. Unnecessarily exposed and vulnerable RPC services can represent high risk.

4. Why are Windows Null Sessions considered a security weakness, and how would you assess their impact?

Answer: Null Sessions can allow anonymous connections without normal authentication. Depending on configuration, they may expose usernames, shares, or system information. Check whether anonymous access is enabled and what information can be obtained. Recommend disabling unnecessary anonymous access.

5. A Windows shared folder allows unauthorized users to access sensitive files. How would you evaluate the severity of this vulnerability?

Answer: Check who can access the folder and what files are exposed. Evaluate whether users have read, write, modify, or delete permissions. Access to sensitive files, especially with modification or deletion rights, increases severity. Correct permissions using least privilege.

6. How would you distinguish between a vulnerable Windows service and a misconfigured Windows service during security testing?

Answer: A vulnerable service has a weakness in the software, such as an outdated version or known flaw. A misconfigured service has insecure settings even when the software itself may not be vulnerable. Check versions, advisories, configuration, permissions, authentication, and network exposure.

7. How would you evaluate the effectiveness of information-gathering techniques against a Windows target?

Answer: Check whether the techniques correctly identify open ports, running services, operating-system details, network information, and other useful data. Compare the results with the actual system configuration. Accurate and useful information indicates effective information gathering.

8. If a Windows vulnerability can be exploited but requires local access, how would you classify its security impact compared with a remotely exploitable vulnerability?

Answer: A local vulnerability normally requires the attacker to already have access to the system. A remote vulnerability can potentially be exploited over a network and therefore usually has wider exposure. However, a local vulnerability can still be serious if it enables privilege escalation or major impact.

9. How would you evaluate the security risks of unconnected or unnecessary services running on a Linux system?

Answer: Identify all running services and determine which are required. Check ports, versions, configurations, permissions, and known vulnerabilities. Unnecessary services increase the attack surface, so they should be stopped and disabled when not needed.

10. Why are rhosts and hosts.equiv considered security risks in Linux? How would you evaluate their impact on system security?

Answer: rhosts and hosts.equiv can create trust-based remote access without strong authentication. Check whether they exist, which hosts and users are trusted, and what access is provided. Unnecessary or unsafe trust relationships should be removed or replaced with stronger authentication.

11. How would you assess whether an NFS configuration exposes sensitive Linux files to unauthorized users?

Answer: Check which directories are exported through NFS, which systems can access them, and what read/write permissions are provided. If sensitive directories are available to unauthorized users or hosts, the configuration is risky. Restrict allowed clients and apply suitable permissions.

12. A Linux file has incorrect permissions that allow unauthorized modification. How would you evaluate the resulting security risk?

Answer: Identify who can modify the file and determine the file's purpose. If it is a configuration file, script, executable, or important system file, unauthorized modification may have high impact. Correct the permissions according to least privilege.

13. How would you compare the security impact of weak file permissions with an unpatched Linux vulnerability?

Answer: Compare exploitability, access required, privileges gained, data affected, and confidentiality, integrity, and availability impact. A remotely exploitable unpatched vulnerability may be more serious than a permission problem affecting an unimportant file.

14. How would you evaluate whether a buffer overflow vulnerability in a Linux application is practically exploitable?

Answer: Confirm the issue in an authorized test environment. Check the affected application version, conditions required, access or privileges needed, and protections such as ASLR or stack protection. Evaluate whether the issue can realistically affect confidentiality, integrity, or availability.

15. Which factors would you consider before selecting an exploitation technique for a Linux vulnerability?

Answer: Consider the vulnerability type, application and OS versions, access requirements, privileges, security protections, possible impact, and testing environment. The technique should be appropriate, safe, and authorized.

16. How would you evaluate the security of a messaging application that stores user credentials or messages insecurely?

Answer: Check where credentials and messages are stored and whether sensitive data is protected. Review encryption, authentication, access control, local storage, databases, backups, and data transmission. Insecure storage of passwords or private messages can create serious security risk.

17. A web application is vulnerable to SQL injection. How would you evaluate the severity of this vulnerability and its possible consequences?

Answer: SQL injection can allow unauthorized interaction with a database when input is handled insecurely. Evaluate the data and functions that could be affected, authentication impact, remote accessibility, and business impact. If sensitive data or authentication can be compromised, severity may be high or critical. Use parameterized queries and safe input handling.

18. How would you determine whether a web application vulnerability represents a critical security risk or a low-risk finding?

Answer: Consider exploitability, access requirements, authentication, affected data, number of users, and confidentiality, integrity, availability, and business impact. Easy exploitation with major impact is critical; difficult exploitation with limited impact is generally lower risk.

19. How would you evaluate the security of a mobile application using a tool such as MobSF?

Answer: MobSF can be used to analyze permissions, insecure storage, hardcoded secrets, APIs, application configuration, communication settings, and other mobile security issues. Review findings, determine severity, collect evidence, and recommend fixes.

20. A mobile application requests unnecessary permissions such as contacts, microphone, and location. How would you evaluate the associated security risk?

Answer: Identify all requested permissions and determine whether each is required for the application's function. Unnecessary access to contacts, microphone, or location can increase privacy and security risks. Apply least privilege and remove unnecessary permissions.

21. How would you evaluate the risk of hardcoded API keys or passwords discovered during mobile application analysis?

Answer: Hardcoded API keys or passwords may be extracted from an application. Check whether they are active, what resources they access, their privilege level, and whether they are shared across users. Revoke or rotate exposed secrets and use secure secret management.

22. If the same vulnerability is found in both a web application and a mobile application, how would you compare their security impact?

Answer: Do not assume the same vulnerability has the same impact. Compare exploitability, attack surface, authentication requirements, affected data, number of users, and business impact in each application. Prioritize the case with greater real-world exposure and impact.

23. How would you select appropriate hacking tools for assessing Windows, Linux, web, and mobile applications?

Answer: Select tools based on the target system and testing objective. Windows and Linux may require network discovery and vulnerability assessment tools; web applications require web security testing tools; mobile applications can be assessed with tools such as MobSF. Consider accuracy, compatibility, safety, coverage, and reporting.

24. After performing vulnerability exploitation, how would you evaluate whether the exploitation technique actually demonstrates a significant security weakness?

Answer: Verify whether the expected result occurred and collect evidence of the security impact. Determine whether confidentiality, integrity, or availability was affected and what access or information was obtained. Document the result and recommend remediation without causing unnecessary damage.

25. You have identified vulnerabilities in Windows, Linux, messaging, web, and mobile applications. How would you prioritize them and prepare a professional security report?

Answer: Verify all findings, classify them as Critical, High, Medium, or Low, and prioritize according to impact, exploitability, exposure, and affected assets. A professional report should include an executive summary, scope, methodology, vulnerability details, affected systems, evidence, severity, impact, recommendations, and remediation priorities.